



Why Margo Needs a Device Identity Foundation

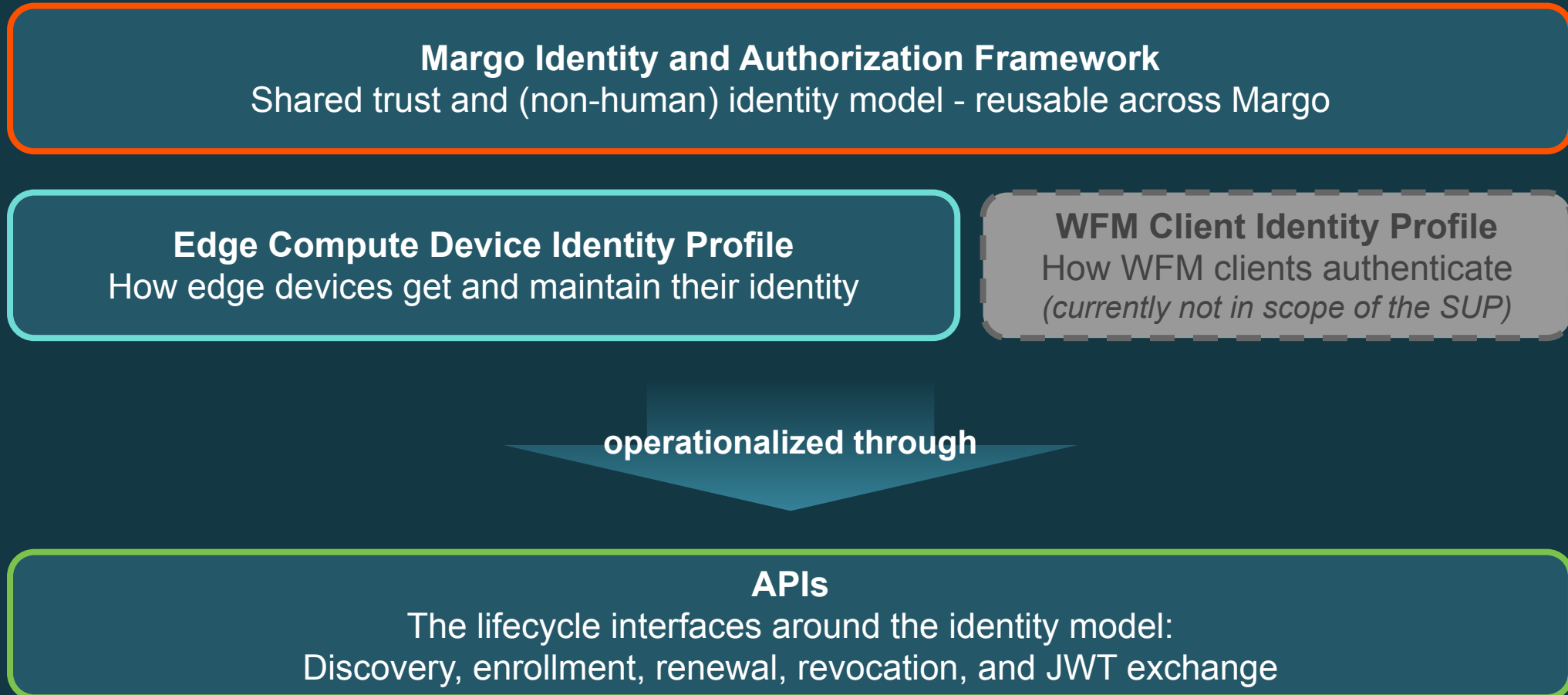
Introducing the MIAF SUP draft

MARCH 26, 2026

PR1 proves interoperability - what comes next?

- PR1 secured the WFM interface: server-side TLS, HTTP Message Signatures (RFC 9421) for client authentication, WFM-assigned `client_id` bound to a client certificate
 - That was the right model for a preview release focused on workload orchestration
- But:
 - The edge device itself does not have its own portable, standard identity - only the WFM Client does
 - When devices and fleet managers come from different vendors, both sides use certificates - but there is no shared model for which root certificates to trust or how to distribute them
 - this becomes even more important once a DFM also needs to verify the same identity
 - There are no rules yet for what happens when a certificate expires, is compromised, or the device is replaced
 - Without a shared foundation, every vendor that implements Margo solves trust in its own way - **which is the opposite of interoperability**

What the SUP proposes



PR1 identifies the client - this SUP identifies the device

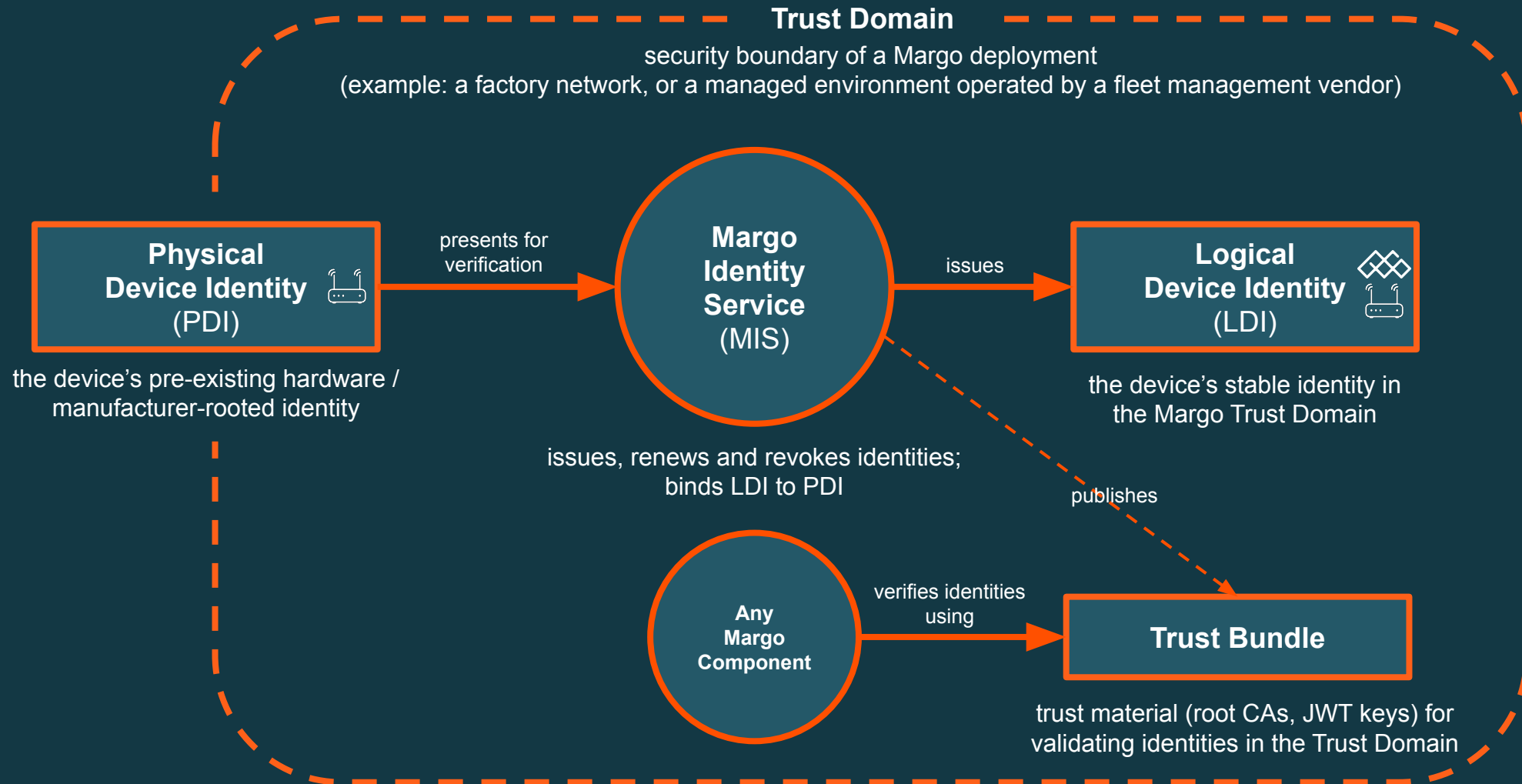
WFM Client Identity under PR1's `client_id` model

- “Which client is talking to this WFM?”
- Recognized by a single, specific WFM
- Assigned by the WFM during client onboarding

Device Identity under the MIAF SUP

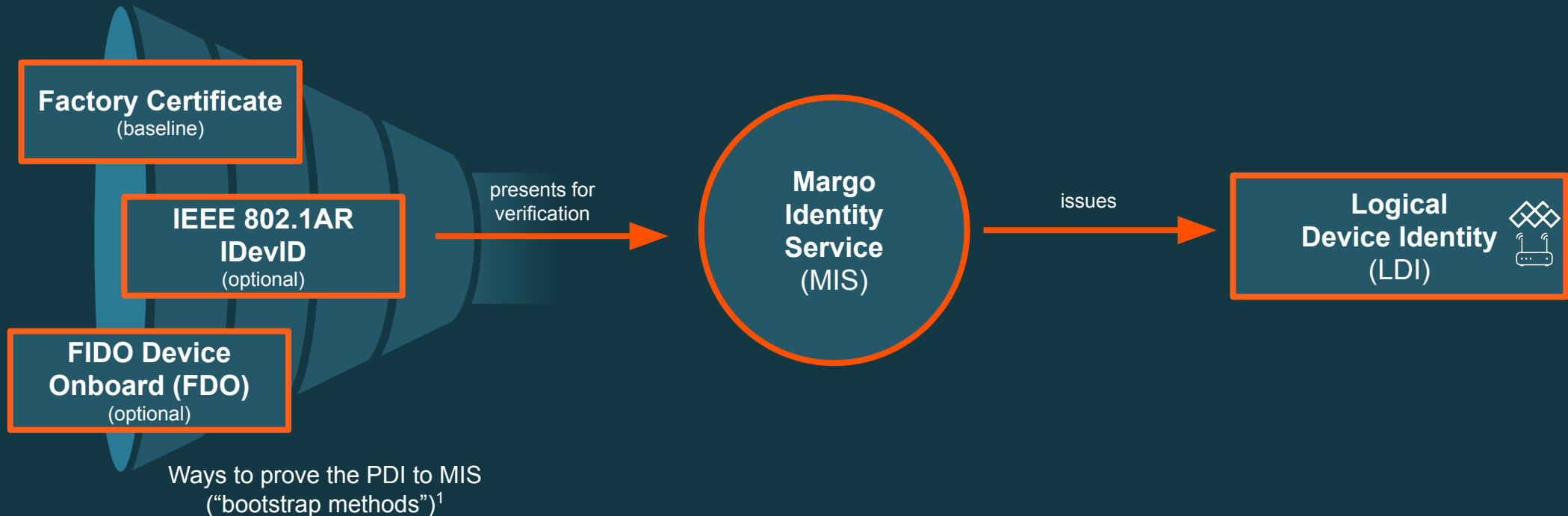
- “Which physical device is this?”
- Verifiable by any Margo component in a deployment
- Rooted in a device bootstrap credential, established at enrollment

How device identity works in one picture



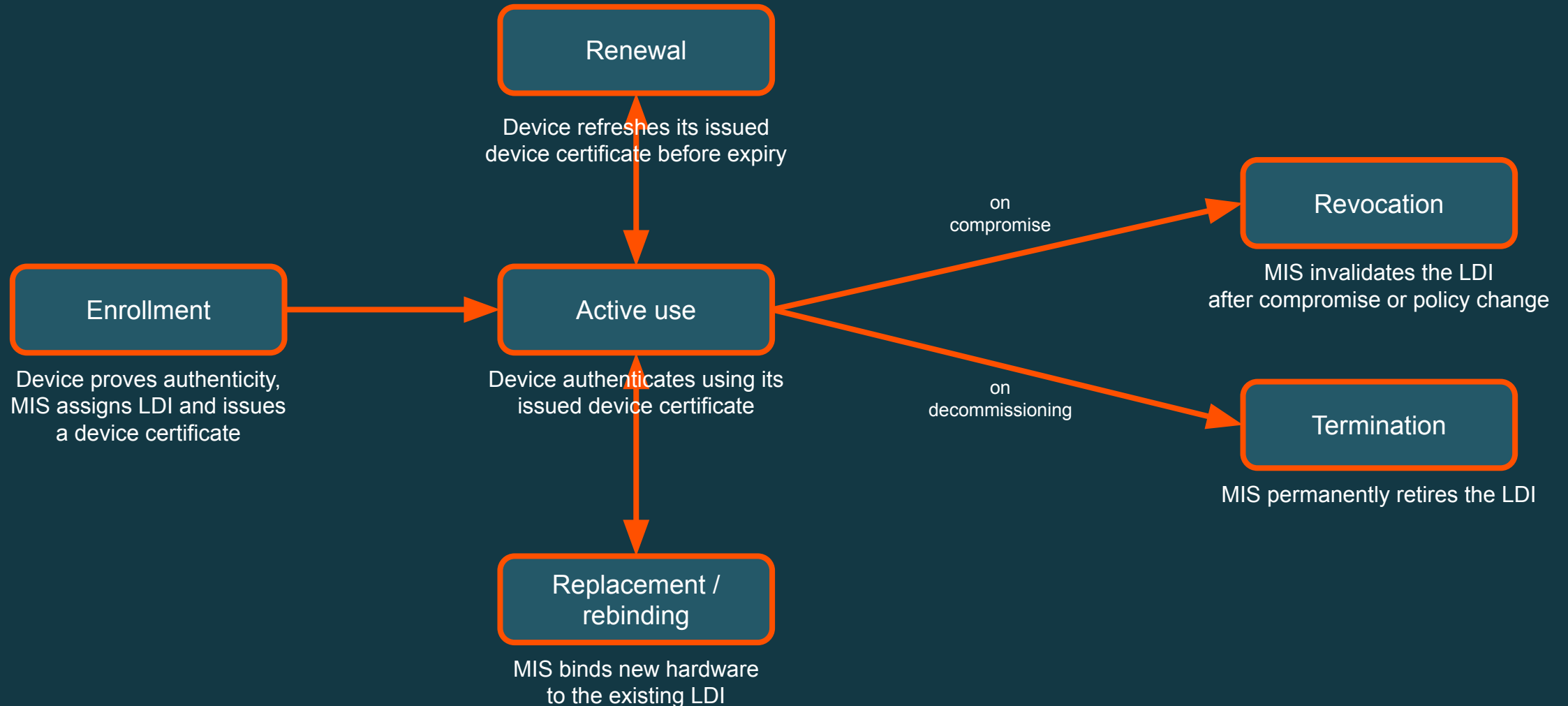
Many ways to establish one Margo device identity

The initial device proof establishes the identity - it is not the Margo device identity



Different bootstrap methods converge on one Logical Device Identity

Device identity is a lifecycle, not a one-time event



Why SPIFFE appears in the SUP

Reusing identity standards for device lifecycle

- Margo needs standard building blocks for identity naming, credential representation, and trust distribution
- SPIFFE, a CNCF standard for non-human identity in cloud-native environments, provides that foundation; the SUP adds device-specific lifecycle around it

Margo needs...	SPIFFE provides...	In this SUP
a trust-domain-scoped identity name	SPIFFE ID	device identity names as <code>spiffe://factory.example/margo/device/cafebabe-dead-4bad-9dad-c0fffeefacade</code>
a standard credential form of that identity	X.509 SVID	the issued device credential is an X.509 SVID
trust anchors for identity validation	Trust Bundle	the Trust Bundle for the trust domain distributed by the MIS
a fallback for non-mTLS environments	JWT-SVID	derived JWT-SVID after enrollment for environments where end-to-end mTLS is not feasible

What this SUP defines - and what it does not

Area	This draft defines	Future work
Identity model	MIAF framework, Edge Compute Device Identity Profile, Trust Domain / MIS / LDI	WFM Client Identity profile; identities for other Margo components
Device lifecycle and APIs	Discovery, enrollment, renewal, revocation, optional JWT exchange	Bootstrap method details still being refined; authorization evidence formats for device replacement
Security baseline	Crypto requirements, TLS requirements, device key-protection requirements	Remote attestation evidence and verification (e.g. hardware-backed keys or measured platform state)

How to read the SUP draft after this talk



Section 3:
MIAF Framework

Trust Domain, MIS, SPIFFE/SVID
grounding, Trust Bundle

Section 4:
Device Identity Profile

LDI, device lifecycle;
bootstrap methods in appendix A

Section 5:
APIs

Discovery, enrollment, renewal,
revocation, JWT exchange

Feedback I'd like from the TWG community

- Does the problem framing resonate?
 - Is PR1 missing a reusable identity and trust foundation?
 - Is the focus on device identity as the first profile reasonable?
- Does the separation of principals make sense?
 - Device identity vs WFM Client identity
- Does the proposed structure seem reasonable?
 - Reusable framework and device profile first, WFM Client profile later
- Where is the draft still unclear, underspecified, or misleading?
- Bootstrap methods
 - who wants to help review or co-spec one?
 - did I miss an important method or approach?
- Who wants to help refine the draft overall?



Thank You

Matthias Lechner

Open Source Architect

 [@matlec](#)

 matthiasl@zededa.com

Key Terms from the SUP

Term	Definition
MIAF	Margo Identity and Authorization Framework - the shared trust and identity model
MIS	Margo Identity Service - the (non-human) identity provider for a Trust Domain
Trust Domain	The security boundary of a Margo deployment within which identities are issued and mutually recognized - defines trust anchors (e.g., root CAs), identity namespace, and policies
Trust Bundle	Root and intermediate certificates (+ JWT public keys) used to validate identities in a Trust Domain
SPIFFE ID	A URI naming an identity within a Trust Domain, e.g. `spiffe://factory.example/margo/device/<uuid>`
SVID	SPIFFE Verifiable Identity Document - the credential binding a SPIFFE ID to a key pair (X.509 or JWT)
PDI	Physical Device Identity - hardware- or manufacturer-rooted credential (“birth certificate”) used during bootstrap
LDI	Logical Device Identity - the persistent, verifiable identity assigned to a device in a Trust Domain
ESI	Enrollment Subject Identifier - deterministic identifier derived from the bootstrap credential; used by MIS to link bootstrap proof to an LDI
Bootstrap Method	A pluggable method by which a device presents its PDI to the MIS for enrollment

MIAF APIs

Endpoint	Method	Path	Purpose
Discovery	GET	<code>/.well-known/margo</code>	Find MIS location, supported bootstrap methods, SVID profiles, Trust Bundle URI
Trust Bundle	GET	URI from discovery	Retrieve trust anchors in SPIFFE Bundle Map format
Enrollment	POST	<code>/api/v1/identities</code>	Present bootstrap credential + CSR → receive X.509 SVID
Renewal	POST	<code>/api/v1/identities/{id}/renewals</code>	Refresh expiring SVID (mTLS or Bearer auth)
JWT Exchange	POST	<code>/api/v1/identities/{id}/jwt-svid</code>	Exchange X.509 SVID for short-lived JWT SVID (for environments that do not support mTLS)
Revocation List	GET	<code>/api/v1/revocations</code>	Machine-readable list of revoked SVIDs

`{id}`: Base64URL-encoded SPIFFE ID

The SUP's relationship with PR1

Aspect	PR1	MIAF SUP
Identity scope	WFM Client only	Edge device itself (LDI)
Trust model	Root CA per WFM instance	Trust Domain with shared Trust Bundle
Onboarding	<code>POST /api/v1/onboarding</code>	<code>POST /api/v1/identities</code>
Trust anchors	<code>GET /api/v1/onboarding/certificate</code>	SPIFFE Trust Bundle endpoint
Credential / certificate lifecycle	Not specified	Explicit lifecycle for identities: enrollment → renewal → replacement → revocation → termination
Key protection	Informational	Normative (hardware protection required where available), see this discussion
WFM Client authentication	<code>client_id</code> + client cert + RFC 9421	Unchanged for WFM client authentication! A device SVID is not a WFM Client credential. PR1's client auth remains until a WFM Client Identity Profile is defined!

MIAF + constrained devices

What are the minimum operations on the device-side?

1. Generate a key pair (e.g., using ECDSA P-256) if not done in the factory
2. Produce a CSR
3. If possible: store the private key securely (TEE, TPM, ...)
4. Present an X.509 client certificate over TLS
5. Parse a JSON enrollment response

Bootstrap Methods

Aspect	Factory Cert (mTLS)	Factory Cert (JWT)	FDO	IEEE 802.1AR
URN (<code>urn:margo:bootstrap:...</code>)	<code>factory-cert-mtls:v1</code>	<code>factory-cert-jwt:v1</code>	<code>fdo:v1</code>	not yet assigned
Status	Mandatory baseline	Optional, stable	Optional, draft (needs validation against FDO spec and likely rework)	Optional, placeholder (needs definition, should be straight-forward)
Auth mechanism	mTLS client certificate	JWT signed with private key	Successful FDO TO2 flow	IDevID in secure element
ESI derivation	SHA-256 of DER leaf cert	SHA-256 of DER leaf cert (<code>x5c[0]</code>)	SHA-256 of DER device cert in voucher	TBD (802.1AR defines uniqueness properties)
Proxy-friendly	No (mTLS required)	Yes (JWT in request body)	Yes (FDO builds its own encrypted channel inside TO2; works over HTTP proxies)	TBD
Requires pre-trusted CA	Yes (manufacturer or operator, see discussion)	Yes (manufacturer or operator, see discussion)	No, trust is voucher-chain based, not CA-based	Yes (manufacturer)

Alternatives considered

Requirements ([#127](#)): device identity lifecycle, inter-vendor authentication, shared trust anchors, a standard Margo identity schema, onboarding flexibility

Alternative	Why not
EST	Enrollment protocol only, not a Margo ecosystem identity strategy (no shared device identity model, trust anchor distribution, or cross-vendor trust semantics)
SCEP	Like EST, but technically even less suitable (weaker fit with modern crypto expectations, legacy protocol shape)
ACME	More modern than EST/SCEP, but still not a Margo ecosystem identity strategy (automates certificate issuance for requested identifiers; does not define shared device identity, trust distribution, or cross-vendor trust semantics)
OAuth 2.0	Useful for scoped authorization later, but not a Margo device identity strategy
Vendor-specific PKI	Breaks inter-vendor interoperability (each vendor brings its own roots, identity rules, and trust distribution model)
Static bearer tokens	No hardware binding, no verifiable device identity, no identity lifecycle